JUNTA DE ANDALUCÍA — MATERIAS COMUNES (A2)

TEMA 25

La Protección de Datos de Carácter Personal y la Seguridad de la Información: El Reglamento (UE) 2016/679 (RGPD) y la Ley Orgánica 3/2018 (LOPDGDD). Principios Rectores de la Protección de Datos. Derechos de las Personas (ARCO-POL). El Delegado de Protección de Datos (DPD). El Esquema Nacional de Seguridad (ENS)

Cuerpo: Cuerpo Técnico Facultativo de la Junta de Andalucía

Grupo: A2

Bloque: Materias Comunes

Tema Oficial: Tema 25

Normativa Clave:

Constitución Española de 1978 (art. 18.4) y Sentencia del Tribunal Constitucional 292/2000.

Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016 (Reglamento General de Protección de Datos - RGPD).

Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (LOPDGDD).

Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad (ENS).

Ley 1/2014, de 24 de junio, de Transparencia Pública de Andalucía (creación y funciones del Consejo de Transparencia y Protección de Datos de Andalucía - CTPDA).

ÍNDICE GENERAL DEL TEMA 25

1. Fundamento constitucional e internacional del derecho a la protección de datos

1.1. El artículo 18.4 de la Constitución Española y la doctrina del Tribunal Constitucional (STC 292/2000)

1.2. Delimitación conceptual: Intimidad vs. Autodeterminación informativa

2. El marco normativo aplicable: El RGPD y la LOPDGDD

2.1. Ámbitos de aplicación material y territorial

2.2. Conceptos nucleares: Dato personal, tratamiento, responsable, encargado, cesión y destinatario

2.3. Bases de legitimación del tratamiento (art. 6 RGPD) y especialidad en el sector público

2.4. Tratamiento de categorías especiales de datos personales (art. 9 RGPD y art. 9 LOPDGDD)

3. Principios rectores de la protección de datos personales

3.1. Principios clásicos: Licitud, lealtad y transparencia

3.2. Limitación de la finalidad y minimización de datos

3.3. Exactitud y limitación del plazo de conservación

3.4. Integridad y confidencialidad (seguridad del tratamiento)

3.5. El principio de responsabilidad proactiva (*accountability*):

3.5.1. Protección de datos desde el diseño y por defecto

3.5.2. El Registro de Actividades de Tratamiento (RAT)

3.5.3. Análisis de riesgos y Evaluación de Impacto en la Protección de Datos (EIPD)

3.5.4. Notificación y gestión de violaciones de seguridad de los datos (data breaches)

4. Los derechos de las personas en materia de protección de datos (Derechos ARCO-POL)

4.1. Régimen general de ejercicio de derechos ante la Administración pública

4.2. Catálogo de derechos:

4.2.1. Derecho de Acceso

4.2.2. Derecho de Rectificación

4.2.3. Derecho de Supresión («derecho al olvido») y sus límites en el sector público

4.2.4. Derecho a la Limitación del tratamiento

4.2.5. Derecho a la Portabilidad de los datos

4.2.6. Derecho de Oposición

4.2.7. Derecho a no ser objeto de decisiones individuales automatizadas y perfiles

4.3. Plazos de respuesta y tutela ante las autoridades de control

5. La figura del Delegado de Protección de Datos (DPD / DPO)

5.1. Obligatoriedad de designación en el sector público (art. 37 RGPD y art. 34 LOPDGDD)

5.2. Posición jurídica, estatuto de independencia y cualificación profesional

5.3. Funciones legales: Asesoramiento, supervisión, cooperación y punto de contacto

5.4. Organización de los DPD en la Administración de la Junta de Andalucía

6. La seguridad de la información: El Esquema Nacional de Seguridad (ENS)

6.1. Marco normativo: El Real Decreto 311/2022

6.2. Principios básicos de seguridad del ENS:

6.2.1. Seguridad integral y gestión de la seguridad basada en los riesgos

6.2.2. Prevención, detección, respuesta y recuperación

6.2.3. Líneas de defensa y vigilancia continua

6.3. Dimensiones de la seguridad: Confidencialidad, Integridad, Trazabilidad, Autenticidad y Disponibilidad (CITAD)

6.4. Categorización de los sistemas de información: Categoría Básica, Media y Alta

6.5. Medidas de seguridad y marco operacional (Marco Organizativo, Operacional y Medidas de Protección)

6.6. Auditorías de seguridad y certificación de conformidad con el ENS

7. Conclusiones y síntesis doctrinal

8. Anexo: Tabla sinóptica de principios, derechos ARCO-POL y dimensiones del ENS

1. FUNDAMENTO CONSTITUCIONAL E INTERNACIONAL DEL DERECHO A LA PROTECCIÓN DE DATOS

El derecho a la protección de datos personales encuentra su anclaje en el **artículo 18.4 de la Constitución Española**, según el cual "*la ley limitará el uso de la informática para garantizar el honor y la intimidad personal y familiar de los ciudadanos y el pleno ejercicio de sus derechos*".

La célebre **Sentencia del Tribunal Constitucional 292/2000, de 30 de noviembre**, consagró la autonomía dogmática de este derecho fundamental, diferenciándolo netamente del derecho a la intimidad del artículo 18.1 CE:

- El **derecho a la intimidad** protege la esfera privada e íntima de la persona frente a intromisiones ajenas.
- El **derecho fundamental a la protección de datos (o libertad informática / autodeterminación informativa)** confiere a la persona el poder de disposición y control sobre sus propios datos personales: qué datos se recaban, quién los posee, con qué fines se tratan, a quién se transmiten y la facultad de exigir su rectificación, cancelación o limitación.

2. EL MARCO NORMATIVO APLICABLE: EL RGPD Y LA LOPDGDD

El régimen jurídico vigente descansa en la integración directa del Derecho de la Unión Europea y el ordenamiento estatal español: 1. **Reglamento (UE) 2016/679 (RGPD):** Norma de aplicación directa en todos los Estados miembros de la UE desde el 25 de mayo de 2018. Armoniza las garantías en el espacio europeo e introduce el principio de responsabilidad proactiva. 2. **Ley Orgánica 3/2018 (LOPDGDD):** Adapta el ordenamiento español al RGPD y añade un título específico (Título X) dedicado a los derechos digitales de la ciudadanía y personas trabajadoras.

2.1. Conceptos nucleares

- **Dato personal:** Toda información sobre una persona física identificada o identificable («el interesado»). Se considera identificable toda persona cuya identidad pueda determinarse mediante identificadores como nombre, DNI, datos de localización, identificador en línea o factores físicos, fisiológicos, genéticos o psíquicos.
- **Tratamiento:** Cualquier operación técnica o conjunto de operaciones aplicadas a datos personales (recogida, registro, organización, conservación, modificación, consulta, comunicación o supresión).
- **Responsable del tratamiento:** Persona física o jurídica, autoridad pública o servicio que determina los fines y los medios del tratamiento (en la Junta: las Consejerías, Direcciones Generales o agencias).
- **Encargado del tratamiento:** Persona o entidad que trata datos personales por cuenta del responsable (ej. empresas de desarrollo informático o soporte tecnológico).

2.2. Bases de legitimación en las Administraciones Públicas (art. 6 RGPD)

En el ámbito del sector público, el tratamiento de datos personales no se fundamenta habitualmente en el consentimiento del ciudadano, sino en bases de legitimación de derecho público:

- **Cumplimiento de una obligación legal** aplicable al responsable del tratamiento (art. 6.1.c RGPD).
- **Cumplimiento de una misión realizada en interés público o en el ejercicio de poderes públicos** conferidos al responsable (art. 6.1.e RGPD y art. 8 LOPDGDD).

2.3. Categorías especiales de datos (art. 9 RGPD)

Se prohíbe con carácter general el tratamiento de datos que revelen el origen étnico o racial, opiniones políticas, convicciones religiosas o filosóficas, afiliación sindical, datos genéticos, datos biométricos dirigidos a identificar de manera unívoca a una persona, datos relativos a la salud o a la vida u orientación sexual.

Su tratamiento por las Administraciones Públicas requiere una **excepción tasada legalmente** (ej. asistencia sanitaria, protección social, salud pública o fines de investigación médica amparados por una norma con rango de ley).

---

3. PRINCIPIOS RECTORES DE LA PROTECCIÓN DE DATOS PERSONALES

El **artículo 5 del RGPD** establece los principios cardinales que deben regir todo tratamiento:

```
PRINCIPIOS SUSTANTIVOS (Art. 5.1 RGPD):
├── 1. Licitud, lealtad y transparencia (información clara y accesible)
├── 2. Limitación de la finalidad (fines determinados, explícitos y legítimos)
├── 3. Minimización de datos (adecuados, pertinentes y limitados a lo necesario)
├── 4. Exactitud (datos exactos y actualizados al día)
├── 5. Limitación del plazo de conservación (solo el tiempo necesario)
└── 6. Integridad y confidencialidad (seguridad frente a accesos no autorizados)
                          │
                          ▼
PRINCIPIO TRANSVERSAL: RESPONSABILIDAD PROACTIVA (Art. 5.2 RGPD - Accountability)
(El responsable debe aplicar medidas técnicas y organizativas y poder DEMOSTRAR su cumplimiento)
```

3.1. Medidas operativas de la Responsabilidad Proactiva (*Accountability*)

- **Privacidad desde el diseño y por defecto (art. 25 RGPD):** Las garantías de protección de datos deben integrarse desde la fase de concepción técnica del procedimiento o software, garantizando por defecto que solo se traten los datos estrictamente imprescindibles.
- **Registro de Actividades de Tratamiento (RAT - art. 30 RGPD y art. 31 LOPDGDD):** Cada órgano de la Junta debe mantener un inventario público y actualizado de todos los tratamientos que realiza, detallando responsables, fines, categorías de datos, cesiones y plazos de conservación.
- **Evaluación de Impacto en la Protección de Datos (EIPD - art. 35 RGPD):** Obligatoria con carácter previo cuando un tratamiento entrañe un alto riesgo para los derechos y libertades de las personas (ej. vigilancia sistemática a gran escala, uso intensivo de datos biométricos o tratamientos masivos de salud).
- **Gestión y notificación de brechas de seguridad (arts. 33 y 34 RGPD):** Si se produce una quiebra de seguridad que afecte a datos personales, el responsable debe notificarla a la autoridad de control (CTPDA / AEPD) en un plazo máximo de **72 horas**, y a los propios afectados cuando exista un alto riesgo.

---

4. LOS DERECHOS DE LAS PERSONAS EN MATERIA DE PROTECCIÓN DE DATOS (DERECHOS ARCO-POL)

El RGPD y la LOPDGDD amplían el catálogo clásico de derechos ARCO (Acceso, Rectificación, Cancelación y Oposición), configurando el bloque de derechos **ARCO-POL**:

4.1. Catálogo sistemático de derechos

1. **Derecho de Acceso (art. 15 RGPD):** Conocer si la Administración está tratando sus datos personales, las finalidades del tratamiento, categorías de datos, destinatarios y plazo previsto de conservación.
2. **Derecho de Rectificación (art. 16 RGPD):** Obtener la modificación o corrección inmediata de los datos inexactos o incompletos.
3. **Derecho de Supresión («derecho al olvido» - art. 17 RGPD):** Exigir la eliminación de los datos cuando ya no sean necesarios para los fines que motivaron su recogida o se hayan tratado ilícitamente.

4. *Límite esencial en el sector público:* El derecho de supresión **no procede** cuando el tratamiento sea necesario para el cumplimiento de una obligación legal o para el ejercicio de potestades públicas (art. 17.3.b RGPD).
5. **Derecho a la Limitación del tratamiento (art. 18 RGPD):** Suspender temporalmente el uso de los datos mientras se comprueba su exactitud o la licitud del tratamiento.
6. **Derecho a la Portabilidad (art. 20 RGPD):** Recibir los datos personales en un formato estructurado, de uso común y lectura mecánica para transmitirlos a otro responsable (no aplicable a tratamientos basados en el ejercicio de poderes públicos).
7. **Derecho de Oposición (art. 21 RGPD):** Oponerse a que los datos sean tratados por motivos relacionados con su situación particular, salvo que la Administración acredite motivos legítimos imperiosos.
8. **Derecho a no ser objeto de decisiones individuales automatizadas (art. 22 RGPD):** No ser sometido a decisiones basadas únicamente en tratamientos automatizados (incluida la elaboración de perfiles) que produzcan efectos jurídicos sustanciales.

4.2. Procedimiento y plazos de respuesta (art. 12 RGPD)

- **Gratuidad:** El ejercicio de estos derechos es estrictamente gratuito para el interesado.
- **Plazo de resolución:** La Administración debe responder a la solicitud en el plazo máximo de **un mes** desde su recepción. Dicho plazo podrá prorrogarse otros **dos meses** adicionales en casos complejos, informando al interesado de los motivos dentro del primer mes.

---

5. LA FIGURA DEL DELEGADO DE PROTECCIÓN DE DATOS (DPD / DPO)

5.1. Obligatoriedad en el sector público

A tenor de los **artículos 37.1.a del RGPD y 34.1.a de la LOPDGDD**, la designación de un Delegado de Protección de Datos es **preceptiva y obligatoria en todas las autoridades y organismos públicos**, incluyendo la Administración de la Junta de Andalucía y sus entidades instrumentales.

5.2. Estatuto de independencia y funciones

- **Independencia funcional (art. 38 RGPD):** El DPD no recibirá instrucciones de ninguna autoridad en el ejercicio de sus funciones. No podrá ser destituido ni sancionado por desempeñar sus cometidos legales y reportará directamente al más alto nivel directivo de la entidad.
- **Cualificación:** Se designa atendiendo a sus cualidades profesionales y conocimientos especializados del Derecho y de la práctica en protección de datos.
- **Funciones legales (art. 39 RGPD):**
- Informar y asesorar al responsable y a los empleados sobre sus obligaciones legales.
- Supervisar el cumplimiento del RGPD, la LOPDGDD y las políticas internas de la entidad.
- Asesorar en la realización de Evaluaciones de Impacto (EIPD) y supervisar su aplicación.
- Actuar como punto de contacto y cooperar con la autoridad de control (el Consejo de Transparencia y Protección de Datos de Andalucía - CTPDA).

---

6. LA SEGURIDAD DE LA INFORMACIÓN: EL ESQUEMA NACIONAL DE SEGURIDAD (ENS)

El **Esquema Nacional de Seguridad (ENS)**, regulado por el **Real Decreto 311/2022, de 3 de mayo**, tiene por objeto establecer los principios básicos, requisitos mínimos y medidas de protección necesarias para garantizar la seguridad de los sistemas, datos, comunicaciones y servicios electrónicos del sector público.

6.1. Principios básicos de seguridad del ENS (arts. 5 a 11 RD 311/2022)

1. **Seguridad integral:** La seguridad debe contemplar los recursos humanos, materiales, normativos y procedimentales.
2. **Gestión basada en los riesgos:** Análisis continuo de amenazas y vulnerabilidades para adoptar medidas proporcionadas.
3. **Prevención, detección, respuesta y recuperación:** Minimizar incidentes, detectar anomalías con celeridad y garantizar la restauración de servicios ante contingencias.
4. **Líneas de defensa:** Organización en múltiples capas de salvaguarda técnicas y organizativas.
5. **Vigilancia continua y reevaluación periódica:** Monitorización constante del estado de seguridad de los sistemas.

6.2. Dimensiones de la seguridad de la información (CITAD)

El ENS evalúa la seguridad en función del impacto que causaría un incidente sobre cinco dimensiones:

- **Confidencialidad:** Garantía de que la información no se pone a disposición ni se revela a individuos no autorizados.
- **Integridad:** Exactitud y completitud de la información y de sus métodos de tratamiento, libre de alteraciones indebidas.
- **Trazabilidad:** Posibilidad de rastrear de forma unívoca el origen, autoría, modificaciones y momentos de tratamiento.
- **Autenticidad:** Certeza e イ ン indubitabilidad de que una entidad o usuario es quien dice ser.
- **Disponibilidad:** Propiedad de que la información y los servicios están accesibles y utilizables cuando lo requieran los usuarios autorizados.

6.3. Categorización de los sistemas y medidas de seguridad

Los sistemas de información se clasifican formalmente en tres niveles en función del impacto potencial ante un fallo:

- **Categoría Básica:** Cuando el perjuicio sea limitado o leve para las funciones de la Administración o derechos ciudadanos.
- **Categoría Media:** Cuando el impacto sea grave o afecte a servicios públicos esenciales o datos sensibles.
- **Categoría Alta:** Cuando las consecuencias causen un daño muy grave o irreparable a la seguridad ciudadana, orden público o derechos fundamentales.

Los sistemas de categoría Media y Alta están sujetos preceptivamente a una **auditoría de seguridad ordinaria cada dos años** y a la obtención formal del Certificado de Conformidad con el ENS.

---

7. CONCLUSIONES Y SÍNTESIS DOCTRINAL

La protección de datos y la seguridad de la información constituyen dos caras de una misma moneda indispensable en el Estado social y democrático de Derecho. Mientras el RGPD y la LOPDGDD consagran el derecho de autodeterminación informativa de la ciudadanía frente a la concentración de datos en manos públicas, el Esquema Nacional de Seguridad (ENS) proporciona la infraestructura técnica, organizativa y de ciberdefensa que blinda la integridad de los servicios digitales de la Junta de Andalucía.

---

8. ANEXO: TABLA SINÓPTICA DE PRINCIPIOS, DERECHOS ARCO-POL Y DIMENSIONES DEL ENS

Dimensión / Figura	Marco Legal	Objeto y Requisitos	Plazo Legal / Efecto
Principio de Licitud	Art. 6 RGPD	Tratamiento amparado en ley o potestades públicas.	Exención de consentimiento en trámites reglados.
Responsabilidad Proactiva	Art. 5.2 RGPD	Demostrar documentalmente la conformidad legal.	RAT, análisis de riesgos y EIPD obligatorios.
Brecha de Seguridad	Art. 33 RGPD	Notificación preceptiva a la autoridad de control.	**Máximo 72 horas** tras tener constancia.
Derechos ARCO-POL	Arts. 15-22 RGPD	Acceso, Rectificación, Supresión, Limitación, etc.	**1 mes** (prorrogable 2 meses más por complejidad).
Supresión en lo público	Art. 17.3 RGPD	Límite del borrado en expedientes administrativos.	Inaplicable si el dato es necesario por ley pública.
Delegado DPD / DPO	Art. 37 RGPD	Supervisión y asesoramiento con independencia.	Obligatorio en toda la Administración de la Junta.
Dimensiones ENS (CITAD)	RD 311/2022	Confidencialidad, Integridad, Trazabilidad, etc.	Evaluación del impacto en escalas Baja, Media, Alta.
Auditoría ENS	Art. 34 RD 311/2022	Verificación periódica en sistemas Medios y Altos.	Obligatoria **cada 2 años**.